

Executive Summary

HealthSecure Global (HSG) is a large healthcare organization with over 5,000 employees and 100 clinic locations that relies on a cloud-based electronic health record (EHR) system to manage protected health information (PHI), financial data, and research records. Strengthening its cybersecurity governance and compliance posture is essential to protecting sensitive data and maintaining regulatory requirements.

This project assesses HSG's risk environment using the NIST Risk Management Framework (SP 800-37) and aligns its security strategy with the NIST Cybersecurity Framework (CSF) 2.0 and NIST SP 800-53. HSG adopts a hybrid cybersecurity governance model that integrates governance processes with technical security controls to improve risk management and regulatory compliance. The analysis identifies Access Control (AC), Incident Response (IR), and Risk Assessment (RA) as the most critical areas for reducing risk and improving security effectiveness.

To address these risks, HSG developed high-level policies focused on securing access to PHI, improving incident response capabilities, and implementing continuous risk management. A gap analysis revealed the need for stronger identity and access controls, formalized incident response procedures, and ongoing monitoring of system vulnerabilities. A phased implementation roadmap prioritizes immediate improvements such as multi-factor authentication and workforce training, followed by long-term investments in monitoring, automation, and advanced security strategies.

Additionally, potential regulatory conflicts between HIPAA and the General Data Protection Regulation (GDPR) are addressed through a risk-based approach to data retention and privacy. By adopting a hybrid cybersecurity framework that integrates NIST standards with healthcare compliance requirements, HSG can reduce organizational risk, improve regulatory alignment, and strengthen its overall security posture while supporting critical healthcare operations.

Organizational Profile

HealthSecure Global (HSG) is a large healthcare organization that consists of approximately 5,000 employees and 100 clinics. The organization utilizes a cloud-based electronic health record system to manage protected health information, financial data, and research records. Due to rapid expansion, HSG must strengthen its cybersecurity governance, risk, and compliance posture to protect sensitive data and maintain regulatory compliance.

Risk Assessment

The organization operates in a high-threat environment where risks to these assets are significant. Cloud misconfigurations and inadequate Identity and Access Management represent the primary root cause of cloud-based breaches, creating the entry points through which ransomware and credential attacks are launched (Cloud Security Alliance, 2024). The risk assessment for HealthSecure Global follows the Risk Management Framework outlined in NIST 800-37, which provides a structured approach to managing organizational risk through a lifecycle of categorizing systems, selecting, and implementing controls, assessing effectiveness, and continuously monitoring security posture.

HSG first identifies and categorizes its critical assets. These assets include cloud-based electronic health record system, research data repositories, protected health information databases, financial and billing systems, network infrastructure, and end-user devices used by healthcare personnel. These systems are necessary to the daily operations and are classified as high-impact due to the sensitivity of the data they store.

The organization operates in a high-threat environment where risks to these assets are significant. Key threats include ransomware attacks targeting the EHR, insider threats involving misuse of authorized access, phishing attacks that can lead to credential compromise, and third-party vendor access associated with external system access. These threats are amplified by vulnerabilities such as insufficient access controls, misconfigured cloud services, and gaps in workforce training.

Within the RMF, these identified risks are used in the selection of appropriate security controls. HSG will prioritize controls associated with access control, incident response, and risk assessment to mitigate the most critical threats. A qualitative analysis approach is used to evaluate the likelihood and impact of each risk, categorizing them as high, moderate, or low based on their potential effect on organizational operations and data confidentiality.

Some high-risk findings include ransomware attacks on the cloud based EHR and insider threats to PHI, both have the potential to significantly disrupt operations and compromise sensitive data. Moderate risks include phishing attacks and cloud misconfigurations, while lower risks involve minor system weaknesses and training deficiencies. Given the regulatory requirements of HIPAA and the critical nature of healthcare data, HSG maintains a low risk tolerance and prioritizes strong security controls to protect its assets.

Overview

To strengthen HealthSecureGlobal’s cybersecurity posture, this phase maps organizational risks and security requirements to the NIST Cybersecurity Framework (CSF) 2.0 and NIST SP 800-53 control families. This alignment ensures that both high-level governance and detailed technical controls are addressed while supporting regulatory compliance requirements such as HIPAA.

Selected Control Families

- Access Control (AC)
- Incident Response (IR)
- Risk Assessment (RA)

NIST CSF Function	SP 800-53 Control Family	How it Applies to HSG
Identify	RA (Risk Assessment)	Identifies risks to PHI, EHR systems, and cloud infrastructure
Protect	AC (Access Control)	Controls access to sensitive data using IAM, RBAC, MFA
Detect	IR (partially)	Detects incidents through monitoring and alerts
Respond	IR (Incident Response)	IR (Incident Response) Handles breaches, ransomware, and unauthorized access
Govern	RA + AC	Establishes risk management and security policies

Mapping to NIST CSF 2.0

Identity and Access Management is a critical component of the Protect function, supporting both Access Control and Identification and Authentication controls to reduce the risk of unauthorized access to cloud-based systems.

Control Justification

The selected control families were chosen based on the results of the risk assessment. Access Control (AC) addresses risks related to unauthorized access and weak identity management, particularly within cloud based EHR systems. Incident Response (IR) is critical for mitigating ransomware and breach scenarios, while Risk Assessment (RA) supports continuous identification and evaluation of threats to organizational assets.

Gap Analysis

A gap analysis was conducted to evaluate HSG's current security posture against the NIST CSF 2.0 Core Functions and selected NIST SP 800-53 control families. The analysis identified three priority areas requiring strengthened controls across the Access Control (AC), Incident Response (IR), and Risk Assessment (RA) control families.

Access Control

HSG should establish and enforce role-based access controls across all clinic locations and cloud environments, ensuring that workforce members can only access PHI relevant to their role. Enterprise-wide multi-factor authentication should be implemented for all systems containing ePHI, and privileged account management procedures should be formalized and regularly reviewed. These improvements align with SP 800-53 controls AC-2 (Account Management), AC-3 (Access Enforcement), and AC-17 (Remote Access), and support the Protect function of CSF 2.0. Implementation of these controls will bring HSG into compliance with the Access Control technical safeguard required under HIPAA at 45 CFR § 164.312(a).

Incident Response

HSG should develop and implement a formal, organization-wide incident response plan that designates a dedicated Incident Response Team establishes documented procedures for containment and eradication and defines measurable response time metrics. Regular tabletop exercises should be conducted to test and refine response capabilities. These steps align with SP 800-53 controls IR-4 (Incident Handling), IR-5 (Incident Monitoring), and IR-8 (Incident Response Plan), and support the Respond and Recover functions of CSF 2.0. A mature incident response capability is essential for meeting HIPAA's 60-day breach notification requirement under 45 CFR §§ 164.400–414.

Risk Assessment

HSG should establish a formalized, continuous risk assessment program that proactively identifies emerging threats, evaluates the effectiveness of existing controls, and drives timely risk response decisions. Vulnerability scanning should be conducted on a regular basis across all systems that store or transmit ePHI. These practices align with SP 800-53 controls RA-3 (Risk Assessment), RA-5 (Vulnerability Monitoring and Scanning), and RA-7 (Risk Response), and support the Identify and Govern functions of CSF 2.0. A formal risk assessment program directly satisfies HIPAA's requirement for an accurate and thorough assessment of potential risks to ePHI under 45 CFR § 164.308(a)(1).

CSF 2.0 Function	Control Family	Key Controls	Current State	Target State	Gap
Protect	AC – Access Control	AC-2, AC-3, AC-17	Partial	Full	High
Respond	IR – Incident Response	IR-4, IR-5, IR-8	Minimal	Full	Critical
Identify / Govern	RA – Risk Assessment	RA-3, RA-5, RA-7	Minimal	Full	Critical

Policy 1: Access Control and PHI Safeguarding Policy

1. Purpose

This policy establishes access control and PHI safeguarding requirements for HealthSecureGlobal in compliance with the Health Insurance Portability and Accountability Act. The primary goal of HIPAA is to protect the privacy of individually identifiable health information (U.S. Department of Health & Human Services [HHS], n.d.). HSG is committed to ensuring that access to protected health information is granted only to authorized individuals and that all PHI is handled in accordance with applicable federal requirements.

2. Scope

This policy applies to all HSG workforce members, contractors, and business associates across all 100 clinic locations who create, access, transmit, or store PHI. It covers all clinical, administrative, and billing systems including the cloud based EHR system, research data repositories, email platforms, cloud storage services, network infrastructure, and end-user devices. All covered entities and business associates are required to comply with the requirements outlined in this policy.

3. Roles and Responsibility

The Chief Information Security Officer holds primary responsibility for overseeing access control compliance across HSG. The IT Security team is responsible for implementing and maintaining all technical access control safeguards including role-based access controls, multi-factor authentication, and audit logging. Clinic Operations Managers are responsible for enforcing access control procedures at the local level and ensuring workforce members only

access PHI relevant to their role. All workforce members are individually accountable for using their access credentials appropriately and reporting any suspected unauthorized access immediately. Business associates must comply with all applicable access control requirements as outlined in executed Business Associate Agreements.

4. Access Control Safeguards

Access to ePHI shall be restricted to authorized users based on the principle of least privilege, ensuring workforce members can only access information necessary to perform their job functions. HSG shall implement the following access control safeguards in alignment with 45 CFR § 164.312(a) and NIST SP 800-53:

Unique User Identification: Every workforce member shall be assigned a unique user ID. Shared or generic accounts are prohibited for accessing systems containing ePHI. User accounts shall be reviewed quarterly and disabled immediately upon termination. These requirements align with NIST SP 800-53 AC-2 (Account Management), with specific attention to AC-2(3) (Disable Accounts), AC-2(9) (Restrictions on Use of Shared and Group Accounts), and AC-2(12) (Account Monitoring for Atypical Usage).

Role-Based Access Control AC-3(7): Access to PHI shall be granted based on the workforce member's role and clinical responsibilities. Access permissions shall be reviewed annually and updated when roles change. These requirements align with NIST SP 800-53 AC-3 (Access Enforcement), with specific attention to AC-3(7) (Role-Based Access Control), which requires access enforcement decisions to be based on approved authorizations for defined roles.

Multi-Factor Authentication: Multi-factor authentication shall be required for all users accessing HSG systems containing ePHI, with mandatory enforcement for all remote access connections. These requirements align with NIST SP 800-53 IA-2 (Identification and

Authentication), with specific attention to IA-2(1) (Multi-Factor Authentication to Privileged Accounts) and IA-2(2) (Multi-Factor Authentication to Non-Privileged Accounts), ensuring MFA is enforced for all workforce members regardless of privilege level. Password and credential management requirements align with IA-5 (Authenticator Management), with specific attention to IA-5(1) (Password-Based Authentication), which requires enforcement of minimum password complexity of 12 characters, 90-day rotation periods, and restrictions on password reuse.

Emergency Access Procedures: Documented emergency access procedures shall be maintained to ensure continuity of care during system outages or emergencies while preserving audit trails. These requirements align with NIST SP 800-53 AC-2(2) (Automated Temporary and Emergency Account Management), ensuring emergency access is controlled, time-limited, and fully auditable.

Automatic Logoff: All systems containing ePHI shall be configured to automatically lock inactive sessions after a defined period to prevent unauthorized access. Session termination shall be enforced for sessions that exceed authorized timeframes. These requirements align with NIST SP 800-53 AC-11 (Device Lock) and AC-12 (Session Termination).

Encryption: ePHI shall be encrypted at rest and in transit using cryptographic mechanisms to prevent unauthorized access or disclosure (45 CFR § 164.312(e)). These requirements align with NIST SP 800-53 SC-28 (Protection of Information at Rest), with specific attention to SC-28(1) (Cryptographic Protection), and SC-8 (Transmission Confidentiality and Integrity), with specific attention to SC-8(1) (Cryptographic Protection), requiring encryption of all ePHI stored across HSG's cloud systems and transmitted between clinic locations.

Policy 2: Incident Response Policy

1. Purpose

This policy establishes requirements for detecting, responding to, and reporting security incidents and PHI breaches at HealthSecure Global. A coordinated and timely incident response capability is essential to meeting HIPAA's breach notification requirements and minimizing harm to patients whose information may be compromised. HSG is committed to maintaining an incident response program that protects patients, preserves organizational integrity, and ensures full regulatory compliance across all 100 clinic locations.

2. Scope

This policy applies to all HSG workforce members, contractors, and business associates involved in processing, storing, or transmitting PHI across all 100 clinic locations, cloud-based systems, and research data repositories. It covers all security incidents and confirms breaches involving HSG information systems, devices, or PHI regardless of where the incident originates.

3. Roles and Responsibilities

The CISO leads the Incident Response Team and holds ultimate accountability for HSG's incident response capability. The Compliance Officer manages all breach notifications to affected individuals and HHS as required by HIPAA. The IT Security team leads technical investigation, containment, and eradication activities. Clinic Operations Managers serve as the first point of contact for incident reports at the local clinic level and are responsible for escalating suspected incidents to the IRT immediately. All workforce members are responsible for reporting suspected security incidents or PHI breaches to their manager and the IT Security team without delay. Business associates must notify HSG of any known or suspected breach involving HSG PHI within the timeframe specified in their Business Associate Agreement.

4. Incident Response Procedures

Detection and Reporting: All security alerts generated by HSG monitoring systems shall be triaged by the IT Security team within four hours of detection. Workforce members who observe suspected unauthorized access or PHI disclosure shall report it immediately to their manager and the IT Security team. These requirements align with NIST SP 800-53 IR-5 (Incident Monitoring), with specific attention to IR-5(1) (Automated Tracking, Data Collection, and Analysis), ensuring HSG's monitoring systems automatically track and analyze security events across all clinic locations and cloud systems.

Containment: Upon confirmation of a security incident the IRT shall immediately implement containment measures to prevent further unauthorized access or data exposure. Containment actions shall be documented in real time including all systems affected, actions taken, and personnel involved. These requirements align with NIST SP 800-53 IR-4 (Incident Handling), with specific attention to IR-4(1) (Automated Incident Handling Processes) and IR-4(2) (Dynamic Reconfiguration), ensuring HSG can rapidly reconfigure systems to contain active threats across its cloud environment.

Eradication and Recovery: Following containment the IRT shall identify and eliminate the root cause of the incident, restore affected systems from verified clean backups, and implement additional controls to prevent recurrence. Recovery actions shall be validated before affected systems are returned to production. These requirements align with NIST SP 800-53 IR-4 (Incident Handling) and IR-9 (Information Spillage Response), with specific attention to IR-9(1) (Responsible Personnel), ensuring designated personnel are responsible for responding to and recovering from information spillage incidents involving PHI.

Post-Incident Review: A post-incident report shall be completed within 14 days of every confirmed security incident. The report shall document the timeline of events, root cause analysis, impact assessment, and corrective actions implemented. Findings shall be used to update this policy and strengthen HSG's security posture. These requirements align with NIST SP 800-53 IR-4 (Incident Handling), with specific attention to IR-4(4) (Information Correlation), ensuring lessons learned from each incident are correlated across HSG's environment to improve future response capabilities.

5. Breach Notification

All confirmed breaches involving PHI shall be reported in accordance with HIPAA's Breach Notification Rule (45 CFR §§ 164.400–414). HSG shall notify affected individuals without unreasonable delay and no later than 60 days following discovery of the breach. Notification shall include a description of the breach, the types of information involved, steps HSG is taking to investigate and mitigate harm, and recommended steps individuals should take to protect themselves. HSG shall notify the U.S. Department of Health & Human Services of all breaches. Breaches affecting 500 or more individuals in a single state shall also require notification to prominent media outlets in that state. These requirements align with NIST SP 800-53 IR-6 (Incident Reporting), with specific attention to IR-6(1) (Automated Reporting) and IR-6(3) (Supply Chain Coordination), ensuring breach reports are generated efficiently and coordinated with affected business associates and vendors.

6. Incident Response Plan

HSG shall maintain a formal written incident response plan that documents roles, responsibilities, procedures, and communication protocols for all phases of incident response. These requirements align with NIST SP 800-53 IR-8 (Incident Response Plan), with specific attention to IR-8(1) (Breaches), which requires the incident response plan to specifically address procedures for responding to breaches of PII and PHI. The plan shall be reviewed and updated annually and following any confirmed security incident.

7. Testing and Exercises

HSG shall conduct annual tabletop exercises and functional drills to test the effectiveness of the incident response plan and identify gaps in procedures or capabilities. These requirements align with NIST SP 800-53 IR-3 (Incident Response Testing), with specific attention to IR-3(2) (Coordination with Related Plans), ensuring incident response exercises are coordinated with related organizational plans including business continuity and disaster recovery. The IRT shall also participate in at least one simulated breach scenario annually to validate notification procedures and response timelines. Exercise findings shall be documented and used to update this policy.

8. Monitoring and Metrics

HSG will track Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), and breach notification timeliness to measure incident response effectiveness. These metrics shall be reviewed by the CISO monthly and reported to executive leadership quarterly.

9. CSF 2.0 Alignment

CSF 2.0 Function	Policy Section	SP 800-53 Controls
Detect	Section 5 — Detection and Reporting	IR-5, IR-5(1)
Respond	Section 5 — Containment	IR-4, IR-4(1), IR-4(2)
Recover	Section 5 — Eradication and Recovery	IR-4, IR-9, IR-9(1)
Respond	Section 6 — Breach Notification	IR-6, IR-6(1), IR-6(3)
Govern	Section 7 — Incident Response Plan	IR-8, IR-8(1)
Respond	Section 8 — Testing and Exercises	IR-3, IR-3(2)

10. Enforcement

Failure to report a suspected security incident or breach in a timely manner constitutes a violation of this policy and will result in disciplinary action. HSG will implement corrective action plans following any confirmed breach to address identified weaknesses and prevent recurrence. Repeated violations shall result in escalated disciplinary measures up to and including termination of employment or contractual agreements.

3. Risk Management Framework

1. Policy

This policy establishes the requirements for identifying, assessing, and managing cybersecurity risks at HealthSecure Global (HSG). The objective of this policy is to ensure that risks to protected health information (PHI), electronic systems, and organizational operations are systematically identified and mitigated in alignment with the NIST Risk Management Framework (RMF) and applicable regulatory requirements such as HIPAA. HSG is committed to

maintaining a proactive risk management program that supports informed decision-making and continuous security improvement.

2. Scope

This policy applies to all HSG workforce members, contractors, and business associates involved in the operation, management, or use of information systems that store, process, or transmit PHI. It covers all organizational assets, including cloud-based systems, EHR platforms, network infrastructure, and end-user devices across all clinic locations.

3. Roles and Responsibilities

The Chief Information Security Officer is responsible for overseeing the enterprise risk management program and ensuring alignment with organizational objectives. The IT Security team is responsible for conducting risk assessments, maintaining risk registers, and implementing risk mitigation strategies. Clinic Operations Managers are responsible for identifying and reporting risks at the local level. All workforce members are responsible for adhering to security practices and reporting potential risks or vulnerabilities. Business associates must comply with HSG's risk management requirements as defined in contractual agreements.

4. Risk Management Process

Risk Identification: HSG shall identify risks to its systems and data through regular assessments, threat intelligence, vulnerability scans, and audits. This aligns with NIST SP 800-53 RA-3 (Risk Assessment).

Risk Analysis and Evaluation: Identified risks shall be analyzed based on likelihood and impact using a qualitative risk model (high, moderate, low). Risk prioritization will guide control selection and mitigation efforts. This aligns with RA-2 (Security Categorization) and RA-3 (Risk Assessment).

Risk Response: HSG shall determine appropriate risk responses, including mitigation, acceptance, transfer, or avoidance. Controls shall be selected and implemented in accordance with NIST SP 800-53 to reduce risk to acceptable levels. This aligns with RA-7 (Risk Response).

Continuous Monitoring: HSG shall continuously monitor risks through automated security tools, vulnerability scanning, and regular security reviews to ensure that its risk posture remains current and responsive to evolving threats. This process aligns with NIST SP 800-53 controls CA-7 (Continuous Monitoring) and RA-5 (Vulnerability Monitoring and Scanning), ensuring both ongoing system oversight and identification of security weaknesses.

6. Risk Register and Reporting

All identified risks shall be documented in a centralized risk register, including risk description, impact level, likelihood, mitigation actions, and ownership. The risk register shall be reviewed quarterly by the CISO and reported to executive leadership to support strategic decision-making.

7. Compliance and Alignment

This policy aligns with the NIST Risk Management Framework and NIST SP 800-53 Risk Assessment (RA) control family. It also supports HIPAA Security Rule requirements for

conducting an accurate and thorough assessment of risks to electronic protected health information (45 CFR § 164.308(a)(1)).

8. Enforcement

Failure to comply with this policy may result in disciplinary action, including termination of employment or contractual agreements. HSG will conduct periodic audits to ensure adherence to risk management processes and continuously improve its risk posture.

9. Conflict Resolution and Resource Constraints

HSG must balance security requirements with operational efficiency and regulatory obligations. Controls such as multi-factor authentication and role-based access control may slow access to electronic health records, particularly in clinical environments requiring rapid decision-making. To address this, HSG will implement role-based and risk-based access controls that maintain strong security while minimizing disruption to patient care.

Incident response actions may also conflict with system availability. Isolating systems during a cybersecurity incident can prevent further damage but may disrupt essential services. HSG will mitigate this by implementing network segmentation and maintaining secure backups, allowing incidents to be contained without halting operations.

In addition to operational conflicts, HSG must address regulatory conflicts between frameworks such as HIPAA and the General Data Protection Regulation. While HIPAA requires the retention of protected health information for legal and medical purposes, GDPR introduces the “right to erasure,” allowing individuals to request deletion of personal data. To resolve this

conflict, HSG will implement data classification, retention policies, and anonymization techniques to ensure compliance with both regulations while maintaining data availability where legally required.

Resource limitations, including budget, staffing, and security tooling, also affect implementation. Given the scale of HSG, it is not feasible to implement all controls simultaneously. Therefore, HSG will prioritize high-impact controls (AC, IR, RA) using a risk-based approach. Cloud-based solutions, automation, and centralized security operations will be leveraged to reduce costs and improve efficiency while maintaining a strong security posture.

10. Governance Model and Executive Recommendations

HealthSecure Global (HSG) will adopt a hybrid cybersecurity governance model that integrates executive oversight, risk management processes, and technical security controls to support both operational resilience and regulatory compliance. This governance model aligns the NIST Cybersecurity Framework (CSF) 2.0 with NIST SP 800-53 control implementation to ensure cybersecurity activities support organizational objectives while protecting sensitive healthcare data. Given the scale of HSG's operations and the sensitivity of protected health information (PHI), cybersecurity governance must involve collaboration between executive leadership, compliance personnel, IT security teams, and clinic operations management.

The Board of Directors and executive leadership team are responsible for establishing organizational risk tolerance, approving cybersecurity strategy, and ensuring sufficient resources are allocated to security initiatives. The Chief Information Security Officer (CISO) will oversee enterprise-wide cybersecurity operations, risk management activities, incident response

coordination, and compliance alignment efforts. The Compliance Officer will ensure adherence to HIPAA, GDPR, and other applicable healthcare regulations, while the IT Security team will implement and maintain technical safeguards across HSG's cloud infrastructure and clinical systems.

To strengthen HSG's long-term cybersecurity posture, executive leadership should prioritize several strategic initiatives. First, HSG should continue investing in identity and access management technologies, including multi-factor authentication and centralized privileged access management, to reduce the risk of unauthorized access to PHI. Second, leadership should support the expansion of continuous monitoring capabilities through Security Information and Event Management (SIEM) platforms and automated threat detection tools. Third, HSG should establish recurring cybersecurity awareness and workforce training programs to reduce human-related risks such as phishing and credential compromise. Finally, executive leadership should conduct quarterly governance and risk review meetings to evaluate security performance metrics, review emerging threats, and ensure alignment between cybersecurity strategy and organizational objectives.

By implementing a strong governance structure supported by continuous oversight and strategic investment, HSG can improve regulatory compliance, strengthen risk management capabilities, and maintain the trust of patients, partners, and stakeholders while supporting secure and reliable healthcare operations.

11. Implementation Roadmap

Short-Term (0–3 Months): HSG will focus on addressing critical security gaps identified in the risk assessment and gap analysis. Immediate actions include implementing multi-factor authentication (MFA) across all systems containing ePHI, enforcing role-based access control (RBAC), and developing a formal incident response plan. Additionally, vulnerability scanning tools will be deployed to identify existing system weaknesses. Workforce members will receive initial security awareness training to reduce risks related to phishing and credential compromise.

Mid-Term (3–12 Months): During this phase, HSG will expand and mature its security capabilities. This includes establishing a centralized Security Information and Event Management system for continuous monitoring, formalizing the Incident Response Team, and conducting regular tabletop exercises. A comprehensive risk management program will be implemented, including the development of a centralized risk register and scheduled risk assessments. Integration of identity and access management systems will also be enhanced to improve access governance across all clinic locations.

Long-Term (12+ Months): HSG will focus on optimization and continuous improvement of its cybersecurity framework. This includes automating security monitoring processes, refining risk assessment methodologies, and conducting annual audits to ensure ongoing compliance with HIPAA and alignment with NIST frameworks. Advanced security measures such as zero trust architecture and enhanced threat intelligence capabilities will be explored. Continuous training programs will be maintained to ensure workforce awareness and adaptability to evolving threats.

References

Cloud Security Alliance. (2024). *Top threats to cloud computing: Egregious eleven*.

<https://cloudsecurityalliance.org>

National Institute of Standards and Technology. (2018). *Risk management framework for information systems and organizations (SP 800-37 Rev. 2)*.

<https://doi.org/10.6028/NIST.SP.800-37r2>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (SP 800-53 Rev. 5)*.

<https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2024). *NIST Cybersecurity Framework (CSF) 2.0*. <https://www.nist.gov/cyberframework>

U.S. Department of Health & Human Services. (n.d.). *Health Insurance Portability and Accountability Act (HIPAA)*. <https://www.hhs.gov/hipaa>

U.S. Department of Health & Human Services. (n.d.). *HIPAA Security Rule*.

<https://www.hhs.gov/hipaa/for-professionals/security/index.html>

U.S. Department of Health & Human Services. (n.d.). *Breach notification rule*.

<https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html>

European Union. (2016). *General Data Protection Regulation (GDPR)*. <https://gdpr.eu>